

Operational Residual Risk & Governance Sign-Off Register

Document Reference: DOC-12

System: Case Ace v2.0 Client Consultation Recording & Note Drafting System

Organisation: Citizens Advice Wandsworth (CAW)

Standard: ISO/IEC 27001:2022 (Clause 6.1.3 & 8.3) & ISO/IEC 42001:2023

Review Frequency: Quarterly / Post-Incident Review

Date of Current Sign-Off: 2026-09-02

Classification: Official-Sensitive / Governance Pack

1. Governance Policy on Risk Disclosure & Acceptance

[!IMPORTANT]

Policy on Residual Risk Transparency:

Citizens Advice Wandsworth maintains a policy of absolute technical honesty. Residual risks are explicitly identified, mathematically and operationally evaluated, assigned to named organizational owners, and accepted at the executive board/leadership level with clear compensating controls.

No residual risk is minimised, obscured, or falsely claimed to be zero.

2. Risk Assessment Scoring Matrix

Risks are evaluated using the standard 5 × 5 Impact / Likelihood matrix:

Likelihood: 1 (Rare), 2 (Unlikely), 3 (Possible), 4 (Likely), 5 (Almost Certain).

Impact: 1 (Insignificant), 2 (Minor), 3 (Moderate), 4 (Major), 5 (Critical).

Risk Score = Likelihood × Impact (1–6: Low/Green; 7–14: Medium/Amber; 15–25: High/Red).

3. Operational Residual Risk Register

RISK-01: JavaScript In-Memory Data Remanence in Browser Heap / OS Swap

Risk Description:

JavaScript running in modern browsers does not provide guaranteed cryptographic memory wiping or deterministic garbage collection. Although `destroySession()` zeroes `TypedArray` audio buffers in-place (`.fill(0)`), string primitives (e.g. intermediate transcript strings, client names) and unreferenced JavaScript objects remain in browser heap memory until the browser's garbage collector cycles. Furthermore, operating system virtual memory paging may write unencrypted heap pages to disk swap or hibernation files (`pagefile.sys`, `swapfile.sys`, `hiberfil.sys`).

Unmitigated Risk: Likelihood: 4, Impact: 4 → Score: 16 (High)

Mandatory Compensating Controls:

Full Disk Encryption (FDE): Mandatory enforcement of BitLocker (Windows 11 Enterprise with XTS-AES 256) or FileVault (macOS Sonoma with APFS encryption) on all CAW managed adviser endpoints.

OS Hibernation Disabled: Endpoint management policy (Microsoft Intune / Jamf Pro) disables OS hibernation (`powercfg -h off`) and sets sleep-to-RAM timeout on all advice consultation laptops.

Strict 15-Minute Inactivity Timeout: Idle sessions automatically trigger `destroySession()` and browser context refresh.

Dedicated Advice Browser Profiles: Advisers use dedicated, hardened browser profiles with zero extensions.

Mitigated Residual Risk: Likelihood: 2, Impact: 2 → Score: 4 (Low)

Named Risk Owner: Head of Operations & IT Infrastructure Lead

Formal Sign-Off: Accepted at Executive Board Information Governance Review (2026-09-02).

RISK-02: Adviser Automation Bias & Review Fatigue

Risk Description:

During high-volume advice sessions, advisers may experience cognitive fatigue and accept AI-generated draft case notes without critically verifying statutory deadlines, debt schedules, or benefit calculations, potentially leading to inaccurate client records or missed mandatory reconsideration windows.

Unmitigated Risk: Likelihood: 4, Impact: 4 $\rightarrow$ Score: 16 (High)

Mandatory Compensating Controls:

Deliberate Friction Gate (Phase 14): The review UI eliminates “Accept All” shortcuts. Low-confidence statements and unverified gaps require individual manual acknowledgment.

Bi-Directional Highlight Audit: Advisers can click any draft note sentence to immediately inspect the source transcript audio segment.

Affirmative Professional Responsibility Sign-off: Before exporting to Casebook CRM, the adviser must click an affirmative confirmation acknowledging sole legal/professional accountability.

Supervisory Sampling Audit: 10% of all AI-assisted case notes undergo retrospective blind peer review by a Lead Supervising Adviser.

Mitigated Residual Risk: Likelihood: 2, Impact: 2 $\rightarrow$ Score: 4 (Low)

Named Risk Owner: Lead Supervising Adviser & Quality Assurance Lead

Formal Sign-Off: Accepted by Bureau Operations Management Team (2026-09-02).

RISK-03: Cloud Sub-Processor API Disruption or Latency Spikes

Risk Description:

Temporary outages, network partitions, or throttling on Google Cloud Platform (europe-west2 Speech-to-Text v2 or Vertex AI Gemini) could interrupt case note drafting during live advice sessions.

Unmitigated Risk: Likelihood: 3, Impact: 3 $\rightarrow$ Score: 9 (Medium)

Mandatory Compensating Controls:

Local-First Fallback Engine: Phase 8 Whisper WASM generates a complete, local-first transcript entirely within the browser. If cloud services fail, the adviser retains the complete local transcript and can author notes manually without data loss.

Automatic Retry with Exponential Backoff: Resilient client retry policy (3 retries with jitter).

Offline Mode Preservation: Transcripts remain in volatile memory and are not lost during network blips.

Mitigated Residual Risk: Likelihood: 2, Impact: 2 $\rightarrow$ Score: 4 (Low)

Named Risk Owner: Technical Systems Lead & IT Operations Manager

Formal Sign-Off: Accepted by IT Steering Committee (2026-09-02).

RISK-04: Rare / Unrecognized Entity Redaction Survivor at Review Gate

Risk Description:

A client or third party disclosing a highly unusual, phonetically ambiguous entity (e.g. rare informal landlord nickname or unformatted foreign reference number) that evades automated Layer 1–3 detection and is overlooked by the adviser during rapid review.

Unmitigated Risk: Likelihood: 3, Impact: 3 $\rightarrow$ Score: 9 (Medium)

Mandatory Compensating Controls:

Multi-Layer Defensive Redaction: Three distinct detection layers (Structured Regex, Contextual NER, and Special Category Classifier).

Fail-Closed Acoustic Verification (Phase 10): Re-transcribes the muted audio stream before cloud transmission. If any identifier sound survives, transmission is aborted.

Zero Data Retention at Processor: Even in the event of an undetected entity, Google Cloud Vertex AI terms guarantee zero data logging, zero disk caching, and zero model training.

Mitigated Residual Risk: Likelihood: 1, Impact: 3 $\rightarrow$ Score: 3 (Low)

Named Risk Owner: Lead Supervising Adviser & Data Protection Officer

Formal Sign-Off: Accepted by DPO & Head of Operations (2026-09-02).

RISK-05: Non-Standard Speech / Heavy Dialect ASR Transcription Inaccuracy

Risk Description:

Clients with severe speech impairments, non-native English accents, or speaking over distressed crying/background noise may experience higher ASR transcription error rates.

Unmitigated Risk: Likelihood: 3, Impact: 3 $\rightarrow$ Score: 9 (Medium)

Mandatory Compensating Controls:

Dual-Pass Transcription (Local Whisper + Cloud Chirp 2): Combines local Whisper WASM with Google Cloud STT v2 configured with UK English acoustic models (chirp_2 / latest_long).

Acoustic Confidence Highlighting: Low-confidence words are visually flagged in amber/yellow for adviser attention.

Audio Scrubbing Toolbar: Advisers can click any phrase to replay the underlying 5-second audio snippet at variable speeds (0.75x, 1.0x, 1.25x).

Mitigated Residual Risk: Likelihood: 2, Impact: 2 $\rightarrow$ Score: 4 (Low)

Named Risk Owner: Lead Training & Accessibility Adviser

Formal Sign-Off: Accepted by Bureau Operations Management Team (2026-09-02).

4. Formal Operational Risk Sign-Off Record